TARMOQ XAVFSIZLIGI

A16. Tarmoq qurilmalarini hardening qilish va audit o‘tkazish

1-VARIANT — Virtual routerni himoyalash va dalilli audit

Mashg‘ulot maqsadi. Talaba Linux asosidagi virtual routerning boshlang‘ich xavfsizlik holatini aniqlaydi, boshqaruv xizmatlarini mustahkamlaydi, ruxsat etilgan trafikni cheklaydi va takroriy audit orqali o‘zgarishlarning samarasini isbotlaydi. Konfiguratsiyani zaxiralash, tiklash va qayta yuklangandan keyin tekshirish bajariladi.

Senariy. Kafedra routerining SSH xizmati barcha interfeyslarda ochiq, parol bilan boshqarish mumkin va keraksiz HTTP sinov xizmati ishlamoqda. Administrator faqat boshqaruv segmentidan, shaxsiy SSH kaliti bilan kirishi kerak. Foydalanuvchi segmentidan router boshqaruviga kirish taqiqlanadi; belgilangan bitta tranzit xizmat ishlashi saqlanadi.

Ko‘rsatkich	1-variant sharti
Fan / semestr	Tarmoq xavfsizligi / faqat 5-semestr
Mashg‘ulot hajmi	2 akademik soat; tayyor obrazlarda taxminan 80 daqiqa
Kompyuter xonasi	30 ta Windows 11 host, o‘zaro LAN va Internet
Har bir host	8 yadroli CPU, 32 GB RAM, SSD 1 TB
Virtualizatsiya	VMware Workstation yoki VirtualBox
VMlar	RTR-SEC, ADMIN, CLIENT — Ubuntu Server 24.04 LTS
Vositalar	OpenSSH, nftables, Nmap, Netplan, systemd, Python 3
Topshiriladigan natija	Oldin/keyin audit, 12 sinov, konfiguratsiyalar, hisobot

Kutiladigan o‘quv natijalari

- Router boshqaruv tekisligi (input) va undan o‘tuvchi trafik (forward) orasidagi farqni ko‘rsatish.
- Keraksiz xizmatni o‘chirish; SSH kaliti, hisob cheklovi va interfeys bo‘yicha boshqaruvni joriy etish.
- Faol va diskda saqlangan sozlamalarni solishtirish, log va tashqi port tekshiruvi bilan xulosani tasdiqlash.
- Audit topilmasini holat, dalil, xavf, tuzatish va qayta sinash natijasi bilan yozish.

Model chegarasi. Ubuntu VM ushbu ishda dasturiy router vazifasini bajaradi. Natijalar ishlab chiqaruvchi firmware’i, switch ASIC’i, Secure Boot yoki barcha CIS talablarining auditi hisoblanmaydi. Tamoyillar haqiqiy routerga ko‘chirilganda uning rasmiy qo‘llanmasi bilan moslashtiriladi.

1. Laboratoriya va dasturiy tayyorgarlik

VM	vCPU / RAM / disk	Adapterlar
RTR-SEC	2 / 2 GB / 20 GB	A16-MGMT va A16-USERS
ADMIN	2 / 2 GB / 20 GB	Faqat A16-MGMT
CLIENT	1 / 2 GB / 20 GB	Faqat A16-USERS

Har kompyuterga jami 6 GB RAM va 60 GB virtual disk yetadi. 30 talaba o‘z hostida mustaqil lab bajaradi. VMlarni import qilish, paketlarni o‘rnatish va sinov konfiguratsiyalarini tayyorlash darsdan oldin bajariladi; bu vaqt asosiy 80 daqiqaga kiritilmaydi.

1.1. O‘qituvchi uchun tayyorlash tartibi

1. Ubuntu Server 24.04 LTS VMlarini yarating; RTR-SECda labadmin nomli sudo huquqli foydalanuvchi yarating. Parol individual bo‘lsin; ADMIN va CLIENTda ham oddiy foydalanuvchi mavjud bo‘lsin.
2. Vaqtinchalik NAT orqali har VMda quyidagi paketlarni o‘rnating. Yangilanishlar tugagach barcha NAT adapterlarini uzing yoki olib tashlang.
3. VirtualBox: Internal Network nomlari A16-MGMT va A16-USERS. VMware: shu nomli ikkita LAN Segment. Router ikki segmentga, endpointlar jadvaldagi bittadan segmentga ulanadi.
4. Bridged va port forwarding ishlatmang. Bu segmentlarda boshqa DHCP/router bo‘lmasin. Har VMda A16-base snapshot va hostga dalil ko‘chirish uchun shared folder tayyorlang.

```
# Har bir VMda:
sudo apt update
sudo apt install -y openssh-server openssh-client nftables nmap \
 netcat-openbsd python3 curl tcpdump nano
# Faqat RTR-SECda; yangi lab obrazida:
sudo ufw disable
sudo systemctl disable --now ssh.socket
sudo systemctl enable --now ssh.service
sudo sshd -t
```

Ubuntu SSH socket activation rejimida ishlashi mumkin. Ushbu variantda ListenAddress sozlamasi aniq qo‘llanishi uchun an’anaviy ssh.service rejimi tanlandi. Agar ssh.socket mavjud bo‘lmasa, shu buyruqdagi “unit not found” xabaridan keyin ssh.service holatini tekshiring. [1, 2]

1.2. Ish boshlash sharti

O‘qituvchi har hypervisor turida kamida bitta to‘liq tajribani oldindan bajarsin. Routerda Docker, boshqa firewall yoki oldingi mashg‘ulot qoidalari bo‘lmasin. Buyruqlar quyida Bash uchun berilgan; PowerShellda bajarilmaydi. Root konsol talab qilinadigan joylar alohida ko‘rsatilgan.

Trafik faqat o‘z virtual labingiz ichida hosil qilinadi. Sinov manzillari xona LANiga chiqarilmaydi. Parol va yopiq SSH kalit hisobotga kiritilmaydi; skrinshotlarda ular ko‘rinmasin.

2. Doimiy IP-manzillar va marshrutlash

Qurilma / interfeys	IPv4 / prefiks	Default gateway
RTR-SEC / MGMT	10.160.10.1/24	Yo‘q
RTR-SEC / USERS	10.160.20.1/24	Yo‘q
ADMIN	10.160.10.10/24	10.160.10.1
CLIENT	10.160.20.10/24	10.160.20.1

Yo‘l: ADMIN — A16-MGMT — RTR-SEC — A16-USERS — CLIENT. Router IP forwarding orqali ikki /24 tarmoqni ulaydi. Internet va DNS bu tajribada talab etilmaydi. MAC manzilni hypervisordagi adapter bilan solishtirib, ip -br link orqali interfeys nomlarini toping.

2.1. Har VM konsolida eski lab IP sozlamasini zaxiralash

```
sudo -i
ip -br link
mkdir -p /root/a16-pre/netplan /opt/a16/evidence
cp -a /etc/netplan/. /root/a16-pre/netplan/
# Faqat yangi, ajratilgan lab VMida:
rm -f /etc/netplan/*.yaml
# Cloud-init mavjud bo'lsa, netplan faylini qayta yozishini to'xtatish:
if test -d /etc/cloud/cloud.cfg.d; then
  echo 'network: {config: disabled}' > /etc/cloud/cloud.cfg.d/99-a16-network.cfg
fi
```

2.2. RTR-SECda /etc/netplan/90-a16.yaml fayli

nano /etc/netplan/90-a16.yaml bilan quyidagini yozing. enp0s3 — MGMT, enp0s8 — USERS namunasi; o‘zingizdagi nomlar bilan almashtiring. YAMLda tab emas, probel ishlating. [3]

```
network:
  version: 2
  renderer: networkd
  ethernets:
    enp0s3:
      dhcp4: false
      dhcp6: false
      addresses: [10.160.10.1/24]
    enp0s8:
      dhcp4: false
      dhcp6: false
      addresses: [10.160.20.1/24]
```

ADMIN va CLIENTda shu faylda faqat bitta interfeys qoldiring. addresses qiymatini jadvalga moslang; uning ostiga routes: qatorini va quyidagi default marshrutni qo‘shing (ADMIN misoli):

```
      routes:
        - to: default
          via: 10.160.10.1
```

Quyidagi buyruqlar YAML fayliga yozilmaydi; har VMning root konsolida bajariladi:

```
# Har VM konsolida:
chmod 600 /etc/netplan/90-a16.yaml
netplan generate && netplan apply
ip -br addr
ip -4 route
```

CLIENT gateway qiymati 10.160.20.1 bo‘ladi. Routerda default route bo‘lmasin. Hozircha faqat o‘z segmentidagi router IPga ping tekshiring; forwarding keyingi qadamda yoqiladi.

3. Boshlang‘ich holat va audit dalillari

3.1. RTR-SEC root konsolida o‘quv bazasini yaratish

Quyidagi yumshoq sozlama faqat ajratilgan o‘quv routeriga tegishli. Asl SSH fayli avval saqlanadi. Bazada root orqali kirish yopiq, ammo labadmin paroli va SSH barcha IPv4 interfeyslarda mavjud bo‘ladi.

```
cp -a /etc/ssh /root/a16-pre/ssh
nft list ruleset > /root/a16-pre/ruleset.nft
cat > /etc/ssh/sshd_config <<'EOF'
Port 22
AddressFamily inet
ListenAddress 0.0.0.0
PermitRootLogin no
PubkeyAuthentication yes
PasswordAuthentication yes
KbdInteractiveAuthentication no
UsePAM yes
Subsystem sftp internal-sftp
EOF
sshd -t && systemctl restart ssh
sysctl -w net.ipv4.ip_forward=1
mkdir -p /var/lib/a16-demo
printf 'A16 demo only\n' > /var/lib/a16-demo/index.html
cat > /etc/systemd/system/a16-demo.service <<'EOF'
[Unit]
Description=A16 temporary HTTP demo
[Service]
User=nobody
ExecStart=/usr/bin/python3 -m http.server 8000 --bind 0.0.0.0 --directory /var/lib/a16-demo
[Install]
WantedBy=multi-user.target
EOF
systemctl daemon-reload
systemctl enable --now a16-demo
ss -lntp
nft list ruleset
```

Kutiladi: 0.0.0.0:22 va 0.0.0.0:8000 tinglanadi. nft qoidalarida bloklovchi siyosat bo‘lmasligi kerak; bo‘lsa oldingi ishni davom ettirmay, toza A16-base obrazidan boshlang. Haqiqiy Telnet yoki SNMPv1 xizmatini o‘rnatish shart emas: TCP/23 asosiy skanga kiritilgan, UDP/161 esa qo‘shimcha tekshiruvdir.

3.2. ADMIN va CLIENTda tashqi boshlang‘ich audit

```
# ADMIN oddiy foydalanuvchisida:
mkdir -p ~/a16-evidence
nmap -sT -Pn -p 22,23,80,443,8000 10.160.10.1 \
 -oN ~/a16-evidence/admin-before.txt
# CLIENTda:
mkdir -p ~/a16-evidence
nmap -sT -Pn -p 22,23,80,443,8000 10.160.20.1 \
 -oN ~/a16-evidence/client-before.txt
```

22 va 8000 — open; qolgan tekshirilgan portlar odatda closed. Bu kutilma, tayyor o‘lchov emas. O‘z natijangizni saqlang. open — tinglovchi xizmat mavjud; closed — javob bor, tinglovchi yo‘q; filtered — filtr sabab port holatini aniq aniqlab bo‘lmaydi. [4]

4. Kalit bilan boshqaruvni tayyorlash

4.1. ADMIN oddiy foydalanuvchisida

ADMINda keyingi SSH buyruqlarini bir xil oddiy foydalanuvchi bajarsin. Kalit uchun passphrase belgilang. Birinchi ulanishda router host key fingerprintini RTR-SEC konsolidagi qiymat bilan solishtiring; faqat mos bo‘lsa tasdiqlang.

```
# RTR-SEC root konsolida fingerprint:
ssh-keygen -lf /etc/ssh/ssh_host_ed25519_key.pub
# ADMINda:
mkdir -p ~/.ssh
chmod 700 ~/.ssh
ssh-keygen -t ed25519 -f ~/.ssh/a16_admin -C 'A16-admin'
ssh-copy-id -i ~/.ssh/a16_admin.pub labadmin@10.160.10.1
# Parolni o'chirishdan AVVAL kalit ishlashini tekshiring:
ssh -i ~/.ssh/a16_admin -o IdentitiesOnly=yes \
 -o PasswordAuthentication=no labadmin@10.160.10.1 'id; hostname'
# Passphrase kiritishni keyingi sinovlarda agent bajaradi:
eval "$(ssh-agent -s)"
ssh-add ~/.ssh/a16_admin
```

ssh-copy-id labadmin hisobining parolini so‘raydi. Keyingi kalit sinovi muvaffaqiyatsiz bo‘lsa hardening bosqichiga o‘tmang. Routerda /home/labadmin/.ssh egasi labadmin, katalog huquqi 700, authorized_keys huquqi 600 bo‘lishi kerak. Yopiq kalit ADMINdan chiqarilmaydi.

4.2. RTR-SECda dastlabki auditni saqlash

```
date -Is > /opt/a16/evidence/before.txt
hostnamectl >> /opt/a16/evidence/before.txt
ip -br addr >> /opt/a16/evidence/before.txt
ip -4 route >> /opt/a16/evidence/before.txt
ss -lntup >> /opt/a16/evidence/before.txt
sshd -T >> /opt/a16/evidence/before.txt
nft list ruleset >> /opt/a16/evidence/before.txt
dpkg-query -W openssh-server nftables >> /opt/a16/evidence/before.txt
stat -c '%U %a %n' /home/labadmin/.ssh \
 /home/labadmin/.ssh/authorized_keys
```

4.3. Tuzatish rejasini oldindan yozish

Topilma	Xavf / ustuvorlik	Rejalashtirilgan nazorat
SSH barcha segmentlarda	Boshqaruv yuzasi keng / yuqori	ListenAddress + manba IP filtri
SSH paroli mavjud	Parol orqali kirish xavfi / o‘rta	Faqat individual public key
Keraksiz HTTP :8000	Ortiqcha xizmat / o‘rta	To‘xtatish va mask qilish
Aniq forward siyosati yo‘q	Keraksiz tranzit / yuqori	Default drop + bitta xizmat
Saqlash/tiklash tekshirilmagan	Nosozlikda tiklanish noaniq / o‘rta	Zaxira, hash, qayta yuklash

Ustuvorliklar ushbu senariy uchun berilgan, CVSS ballari emas. Auditda “topilmadi” va “tekshirilmadi” holatlarini farqlang. Bitta port skani qurilmaning to‘liq xavfsizligini isbotlamaydi.

5. SSH va xizmatlarni hardening qilish

5.1. RTR-SEC root konsolida boshqaruv siyosati

Yangi lab routerida konfiguratsiya to‘liq va aniq beriladi: Include yoki Match bloklari bilan ustuvorlik ziddiyati qolmaydi. Amaldagi qurilmada esa mavjud siyosatni audit qilmasdan faylni to‘liq almashtirish mumkin emas. OpenSSHda ko‘p parametrlar uchun birinchi o‘qilgan qiymat qo‘llanadi; yakuniy holat sshd -T orqali tekshiriladi. [1, 5]

```
cat > /etc/ssh/sshd_config <<'EOF'
Port 22
AddressFamily inet
ListenAddress 10.160.10.1
PermitRootLogin no
PubkeyAuthentication yes
AuthenticationMethods publickey
PasswordAuthentication no
KbdInteractiveAuthentication no
PermitEmptyPasswords no
AllowUsers labadmin@10.160.10.10
UsePAM yes
MaxAuthTries 3
LoginGraceTime 30
AllowTcpForwarding no
AllowAgentForwarding no
AllowStreamLocalForwarding no
X11Forwarding no
PermitTunnel no
LogLevel VERBOSE
Banner /etc/issue.a16
Subsystem sftp internal-sftp
EOF
printf 'A16: faqat ruxsat etilgan boshqaruv.\n' > /etc/issue.a16
chmod 600 /etc/ssh/sshd_config
sshd -t && systemctl restart ssh
sshd -T | grep -E 'listenaddress|authenticationmethods|passwordauthentication'
sshd -T | grep -E 'permitrootlogin|allowusers'
systemctl disable --now a16-demo
# /etc dagi maxsus unit faylini saqlab, mask uchun joy bo'shatish:
mv /etc/systemd/system/a16-demo.service /root/a16-pre/
systemctl daemon-reload
systemctl mask a16-demo.service
ss -lntp
```

Kutiladi: SSH faqat 10.160.10.1:22 da; 8000 tinglovchisi yo‘q; xizmat masked. Kalit bilan ADMINdan yangi SSH sessiyasini tekshiring. Root konsolni ish tugaguncha ochiq qoldiring. Portni 22 dan boshqa raqamga almashtirish autentifikatsiya yoki ruxsat nazorati o‘rnini bosa olmaydi.

5.2. Hisob vakolatlarini baholash

labadmin — shaxsiy administrator, kundalik kirish root nomidan bajarilmaydi; zarur buyruqlar sudo orqali bajariladi. sudo -l -U labadmin natijasini hisobotga yozing. Ushbu labda to‘liq sudo saqlanadi; ishlab chiqarishda vazifaga mos rollar ajratiladi. SSH forwardingni o‘chirish shell huquqli foydalanuvchining barcha mumkin bo‘lgan tunnellarini bartaraf etmaydi. [5]

6. Router yadrosi va jurnal siyosati

6.1. Doimiy kernel parametrlarini sozlash

RTR-SEC root konsolida bajaring. ip_forward avval yoqiladi; keyin qolgan parametrlar yoziladi, chunki forwarding o‘zgarishi ayrim tarmoq parametrlarini qayta o‘rnatishi mumkin. rp_filter=2 qaytish marshruti mavjudligini yumshoq rejimda tekshiradi; bu firewallning manba nazoratini almashtirmaydi. [6]

```
cat > /etc/sysctl.d/90-a16-router.conf <<'EOF'
net.ipv4.ip_forward=1
net.ipv6.conf.all.forwarding=0
net.ipv4.conf.all.accept_redirects=0
net.ipv4.conf.default.accept_redirects=0
net.ipv4.conf.all.send_redirects=0
net.ipv4.conf.default.send_redirects=0
net.ipv4.conf.all.accept_source_route=0
net.ipv4.conf.default.accept_source_route=0
net.ipv4.conf.all.rp_filter=2
net.ipv4.conf.default.rp_filter=2
EOF
# Nomlarni o'z adapterlaringizga moslang:
for nic in enp0s3 enp0s8; do
  for opt in accept_redirects send_redirects accept_source_route; do
    echo "net.ipv4.conf.$nic.$opt=0" >> /etc/sysctl.d/90-a16-router.conf
  done
done
sysctl -p /etc/sysctl.d/90-a16-router.conf
sysctl net.ipv4.ip_forward net.ipv4.conf.all.rp_filter
```

6.2. Qayta yuklanganda saqlanadigan log

```
mkdir -p /etc/systemd/journald.conf.d
cat > /etc/systemd/journald.conf.d/90-a16.conf <<'EOF'
[Journal]
Storage=persistent
SystemMaxUse=100M
EOF
mkdir -p /var/log/journal
systemd-tmpfiles --create --prefix /var/log/journal
systemctl restart systemd-journald
journalctl --flush
logger -t A16 'Hardening bosqichi bajarildi'
journalctl -t A16 --no-pager
journalctl --disk-usage
```

Jurnalni saqlash hajmi chegaralangan. Lab vaqtini date -Is bilan har VMda tekshiring; Internet uzilganligi sabab tashqi NTPga tayanmang. Turli VM loglarini solishtirishda vaqt farqini hisobotga qayd eting. Markaziy log serveri bu variantning majburiy qismi emas. [7]

6.3. Yangilanish holati

Paketlar darsdan oldin ishonchli Ubuntu repozitoriysidan yangilanadi. Auditda uname -r va dpkg-query -W openssh-server nftables natijalarini yozing. Paket versiyasi yoki oldindan yuklangan apt ro‘yxatining o‘zi “barcha zaifliklar yopilgan” degan xulosa uchun yetarli emas; yangi xavfsizlik yangilanishlarini tekshirish o‘qituvchining Internetga ulangan tayyorgarlik bosqichida bajariladi.

7. Router firewalli: boshqaruv va tranzit

RTR-SECda /etc/nftables.conf faylini quyidagicha yarating. Bu toza, maxsus lab routeri: flush ruleset uning barcha nft qoidalarini almashtiradi. enp0s3/enp0s8 nomlarini moslang. inet jadvali IPv4 va IPv6ga qo‘llanadi; ushbu variantda faqat belgilangan IPv4 oqimlari ruxsat etiladi. [8]

```
cat > /etc/nftables.conf <<'EOF'
#!/usr/sbin/nft -f
flush ruleset
table inet a16 {
  chain input {
    type filter hook input priority 0; policy drop;
    iifname "lo" accept
    iifname "enp0s3" ip saddr != 10.160.10.0/24 counter drop
    iifname "enp0s8" ip saddr != 10.160.20.0/24 counter drop
    ct state invalid counter drop
    ct state established,related accept
    iifname "enp0s3" ip saddr 10.160.10.10 ip daddr 10.160.10.1 tcp dport 22 counter accept
    iifname "enp0s3" ip saddr 10.160.10.10 ip protocol icmp icmp type echo-request counter accept
    limit rate 3/second burst 5 packets log prefix "A16-IN-DROP "
    counter drop
  }
  chain forward {
    type filter hook forward priority 0; policy drop;
    iifname "enp0s3" ip saddr != 10.160.10.0/24 counter drop
    iifname "enp0s8" ip saddr != 10.160.20.0/24 counter drop
    ct state invalid counter drop
    ct state established,related accept
    iifname "enp0s8" oifname "enp0s3" ip saddr 10.160.20.10 ip daddr 10.160.10.10 tcp dport 8080 \
      counter accept
    limit rate 3/second burst 5 packets log prefix "A16-FWD-DROP "
    counter drop
  }
  chain output {
    type filter hook output priority 0; policy accept;
  }
}
EOF
nft -c -f /etc/nftables.conf && nft -f /etc/nftables.conf
systemctl enable nftables
nft -a list table inet a16
```

Kutiladi: input va forward siyosati drop; ADMINning SSH ulanishi saqlanadi. CLIENTdan ADMINdagi TCP/8080 xizmati uchun yagona yangi tranzit oqim ruxsat etiladi. Javoblar conntrack orqali qaytadi. Output accept — routerning o‘zi boshlagan trafik ushbu labda cheklanmagan; buni audit qamrovida ochiq yozing.

Log cheklovi faqat yoziladigan xabarlar soniga tegishli. Keyingi counter drop qoidasida limit yo‘q, shu sabab log limitidan oshgan paketlar ham tashlab yuboriladi. Manba IP cheklovi MAC/IP soxtalashtirishdan to‘liq himoya bermaydi; MGMT segmentiga faqat vakolatli administrator qurilmasi ulanadi.

8. Ijobiy va salbiy funksional sinovlar

8.1. ADMINda xizmat va boshqaruvni tekshirish

```
# ADMINda alohida terminal; ish oxirida Ctrl+C:
mkdir -p ~/a16-service
printf 'A16 tranzit OK\n' > ~/a16-service/index.html
python3 -m http.server 8080 --bind 10.160.10.10 --directory ~/a16-service
# ADMINning boshqa terminalida (ssh-agent kaliti yuklangan):
ssh -i ~/.ssh/a16_admin -o IdentitiesOnly=yes \
 labadmin@10.160.10.1 'id; hostname'
# Kalit va interaktiv parolni ishlatmasdan salbiy sinov:
ssh -o BatchMode=yes -o PubkeyAuthentication=no \
 -o PreferredAuthentications=password labadmin@10.160.10.1 true
# Root kirishi ham rad etilishi kerak:
ssh -i ~/.ssh/a16_admin -o IdentitiesOnly=yes -o BatchMode=yes \
 root@10.160.10.1 true
nmap -sT -Pn -p 22,23,80,443,8000 10.160.10.1 \
 -oN ~/a16-evidence/admin-after.txt
```

Birinchi SSH buyrug‘i labadmin identifikatorini qaytaradi. Keyingi ikki urinish Permission denied bilan tugaydi. ADMIN skanida 22 open, qolgan tekshirilgan portlar filtered bo‘lishi kutiladi. BatchMode ishlashi uchun agentga kalit 4-bo‘limda yuklangan bo‘lishi kerak.

8.2. CLIENTda router va tranzit chegaralari

```
curl --connect-timeout 3 --max-time 5 http://10.160.10.10:8080/
nc -vz -w 3 10.160.10.10 22
nc -vz -w 3 10.160.10.1 22
nmap -sT -Pn -p 22,23,80,443,8000 10.160.20.1 \
 -oN ~/a16-evidence/client-after.txt
# RTR-SECda sinovlardan keyin:
journalctl -k --since '-10 min' --no-pager | grep 'A16-'
journalctl -u ssh --since '-10 min' --no-pager | tail -n 30
nft -a list table inet a16
```

CLIENT curl javobi A16 tranzit OK bo‘lsin. ADMIN:22 va router MGMT:22 ulanishlari timeout; CLIENT tomonidan router USERS manzilidagi barcha tekshirilgan portlar filtered bo‘lishi kerak. Routerdagi ss -lntp natijasida esa 8000 umuman tinglanmayotgani tasdiqlanadi. Shunday qilib “xizmat o‘chgan” va “filtr to‘smoqda” dalillari ajratiladi.

8.3. Sinov mezoni

Salbiy sinovda faqat xato matniga tayanmang: mos source/destination va vaqt bilan firewall logini yoki counter o‘sishini yozing. Log rate limit sabab har paket uchun xabar chiqmasligi mumkin. Tarmoq timeoutini SSH autentifikatsiya rad javobi bilan aralashtirmang. UDP/161 faqat qo‘shimcha tekshiriladi; UDP skanidagi open|filtered xizmat yo‘qligini isbotlamaydi. [4]

9. Konfiguratsiya auditini takrorlash

RTR-SECda /opt/a16/audit.sh faylini yarating. Bu 10 ta aniq holatni tekshiruvchi yordamchi skript; tashqi ruxsat sinovlari va to‘liq xavfsizlik auditi o‘rnini bosmaydi. check funksiyasida xato natija FAIL bo‘ladi, skript qolgan tekshiruvlarni davom ettiradi.

```
cat > /opt/a16/audit.sh <<'EOF'
#!/usr/bin/env bash
export LC_ALL=C
check() {
  local name="$1"; shift
  if "$@"; then echo "PASS | $name"; else echo "FAIL | $name"; fi
}
sshval() { /usr/sbin/sshd -T | grep -Fxq "$1"; }
check '01 root SSH yopiq' sshval 'permitrootlogin no'
check '02 parol yopiq' sshval 'passwordauthentication no'
check '03 faqat publickey' sshval 'authenticationmethods publickey'
check '04 faqat labadmin va ADMIN IP' sshval 'allowusers labadmin@10.160.10.10'
check '05 faqat MGMT listener' bash -c \
 'test "$(/usr/sbin/sshd -T | grep "^listenaddress ")" = "listenaddress 10.160.10.1:22"'
check '06 demo masked' bash -c \
 'test "$(systemctl is-enabled a16-demo.service 2>/dev/null)" = masked'
check '07 IPv4 routing yoqilgan' bash -c \
 'test "$(sysctl -n net.ipv4.ip_forward)" = 1'
check '08 input default drop' bash -c \
 'nft list chain inet a16 input 2>/dev/null | grep -q "policy drop"'
check '09 forward default drop' bash -c \
 'nft list chain inet a16 forward 2>/dev/null | grep -q "policy drop"'
check '10 firewall bootda yoqiladi' systemctl is-enabled --quiet nftables
EOF
chmod 700 /opt/a16/audit.sh
/opt/a16/audit.sh | tee /opt/a16/evidence/audit-after.txt
ss -lntup > /opt/a16/evidence/listeners-after.txt
sshd -T > /opt/a16/evidence/sshd-after.txt
nft list ruleset > /opt/a16/evidence/firewall-after.txt
journalctl -u ssh --since '-20 min' --no-pager \
 > /opt/a16/evidence/ssh-log.txt
journalctl -k --since '-20 min' --no-pager | grep 'A16-' \
 > /opt/a16/evidence/firewall-log.txt
```

Kutiladi: 10 ta PASS. FAIL bo‘lsa sozlamani tuzating, mos funksional sinovni takrorlang va avvalgi dalilni o‘chirmasdan yangi natija saqlang. Skript AllowUsers qiymati va default policy’ni tekshiradi, lekin barcha nft qoidalari to‘g‘ri ekanini yoki kalit amalda ishlashini o‘zi isbotlamaydi.

Topilmani yozish namunasi

F-01: “CLIENTdan router SSH portiga ulanish mumkin edi”. Dalil: client-before.txt da 22/open. Tuzatish: MGMT ListenAddress, AllowUsers va input filtri. Qayta sinov: CLIENTdan timeout, A16-IN-DROP yoki counter o‘sishi; ADMINdan kalit bilan muvaffaqiyatli kirish. Holat: dalillar mavjud bo‘lsa “bartaraf etildi”.

10. Zaxiralash, tiklash va reboot auditi

10.1. RTR-SECda tasdiqlangan holatni saqlash

```
mkdir -p /root/a16-good
chmod 700 /root/a16-good
cp -a /etc/ssh/sshd_config /root/a16-good/sshd_config
cp -a /etc/issue.a16 /root/a16-good/issue.a16
tar -czf /root/a16-good/config.tar.gz \
 /etc/netplan/90-a16.yaml /etc/ssh/sshd_config /etc/issue.a16 \
 /etc/nftables.conf /etc/sysctl.d/90-a16-router.conf \
 /etc/systemd/journald.conf.d/90-a16.conf \
 /home/labadmin/.ssh/authorized_keys
chmod 600 /root/a16-good/*
cd /root/a16-good
sha256sum config.tar.gz > config.sha256
sha256sum -c config.sha256
```

config.tar.gz — konfiguratsiyalar nusxasi; u to‘liq disk obrazi emas, paketlar, hisob paroli, SSH host private keylari va systemd enable/mask holatini to‘liq tiklamaydi. To‘liq tiklanish uchun A16-hardened snapshot ham oling. Arxiv root katalogida saqlanadi; hisobotga arxiv mazmuni o‘rniga fayl ro‘yxati va hash natijasi yetarli.

10.2. Boshqariladigan o‘zgarish va tanlab tiklash

```
# RTR-SEC konsolida; xavfsizlikni bo'shashtirmaydigan o'zgarish:
sed -i 's/^MaxAuthTries 3$/MaxAuthTries 2/' /etc/ssh/sshd_config
sshd -t && systemctl reload ssh
sshd -T | grep '^maxauthtries '
# Yaxshi nusxadan faqat o'zgargan konfiguratsiyani qaytarish:
cp -a /root/a16-good/sshd_config /etc/ssh/sshd_config
sshd -t && systemctl reload ssh
cmp /etc/ssh/sshd_config /root/a16-good/sshd_config && echo RESTORE_OK
sshd -T | grep '^maxauthtries '
reboot
```

Kutiladi: avval maxauthtries 2, tiklashdan so‘ng 3 va RESTORE_OK. ADMINdagi 8080 terminalini ochiq qoldiring; faqat RTR-SECni qayta yuklang. Keyin router konsolida quyidagilarni bajaring, ADMIN va CLIENTdan 8-bo‘limdagi ijobiy hamda salbiy sinovlarni qaytaring.

```
sudo -i
ip -br addr
sysctl -n net.ipv4.ip_forward
systemctl is-active ssh nftables
/opt/a16/audit.sh | tee /opt/a16/evidence/audit-reboot.txt
journalctl --list-boots
journalctl -t A16 --no-pager
```

Aloqa yo‘qolsa: VM konsolidan IP va sshd -t ni tekshiring; faqat noto‘g‘ri faylni /root/a16-good nusxasidan tiklang. Firewall uchun saqlangan /etc/nftables.conf ni nft -c bilan tekshirib qayta yuklang. Murakkab nosozlikda A16-hardened snapshotga qayting. Firewallni butunlay o‘chirish yakuniy tuzatish sifatida qabul qilinmaydi.

11. Natijalarni qayd etish va nosozliklarni tahlil qilish

ID	Sinov / kutiladigan natija	Amaldagi natija va dalil
T1	Oldin: ADMIN va CLIENTdan 22,8000 open	_____
T2	ADMIN kalit bilan labadmin sifatida kiradi	_____
T3	Kalitsiz/parol usuli bilan kirish rad	_____
T4	Root SSH kirishi rad	_____
T5	CLIENT → router USERS:22 filtered	_____
T6	CLIENT → router MGMT:22 timeout	_____
T7	Routerda :8000 listener yo‘q; demo masked	_____
T8	CLIENT → ADMIN:8080 javobi mavjud	_____
T9	CLIENT → ADMIN:22 timeout, forward dalili	_____
T10	Auditda 10 PASS; dalillar mos	_____
T11	MaxAuthTries 2 → 3; RESTORE_OK	_____
T12	Rebootdan so‘ng T2, T5, T8, T9 saqlanadi	_____

Keng tarqalgan nosozliklar

Belgi	Tekshirish va tuzatish
Netplan xatosi	Indentatsiya, interfeys nomi, fayl huquqi; netplan generate.
SSH kalit rad etiladi	ADMIN foydalanuvchisi, ssh-agent, authorized_keys egasi/600, ssh logi.
SSH hali 0.0.0.0 da	ssh.socket holati, sshd -T va ss; service rejimini tekshirish.
CLIENT curl ishlamaydi	ADMINda 8080 listener, endpoint gateway, ip_forward, forward counter.
Log ko‘rinmaydi	Yangi ulanish yuboring; rate limit va journalctl -k vaqt oralig‘i.
Rebootdan so‘ng qoida yo‘q	nftables enabled, /etc/nftables.conf sintaksisi va journalctl -u nftables.

Hisobotda T1–T12 uchun PASS/FAIL, vaqt va dalil faylini yozing. Biror sinov bajarilmasa “bajarilmadi” deb belgilang va sababini ayting. Jadvaldagi kutilmalarni o‘lchangan natija sifatida ko‘chirmang.

12. Mustaqil topshiriq, vaqt va baholash

Talaba bajaradigan ishlar

1. Uch VM va ikkita segmentni yarating; har interfeys IPsi hamda gatewayni sxema yoki jadval bilan hujjatlashtiring.
2. Kamida beshta boshlang‘ich topilmani dalil, xavf va tuzatish rejasi bilan yozing.
3. Kalit ishlashini tasdiqlab, SSH va ortiqcha xizmatni hardening qiling.
4. Routerda input va forward siyosatini joriy eting; har ruxsat qoidasining vazifasini izohlang.
5. T1–T12 sinov jadvalini haqiqiy natijalar bilan to‘ldiring; kamida bir input va bir forward drop dalilini saqlang.
6. Konfiguratsiyani zaxiralang, boshqariladigan o‘zgarishni tiklang va reboot auditini bajaring.
7. Kamida uchta qolgan cheklovni yozing: masalan, output accept, MGMTdagi IP soxtalashtirish, markaziy log yo‘qligi. Har biri uchun keyingi chora taklif qiling.

80 daqiqalik tavsiya etilgan taqsimot

Bosqich	Daqiqa
VM/IP va boshlang‘ich audit	15
SSH kaliti va xizmat hardeningi	15
Kernel, jurnal va firewall	20
Funksional sinovlar va audit	15
Zaxira, tiklash, reboot va hisobot	15
Jami	80

O‘qituvchi kod shablonlarini oldindan elektron shaklda bersa 80 daqiqaga yaqin bajariladi. VM importi va paket yuklash oldindan bajariladi. Xatolarni izlash cho‘zilsa, hisobotni rasmiylashtirish darsdan tashqarida yakunlanishi mumkin.

Baholash mezoni — 10 ball

Mezon	Ball
To‘g‘ri topologiya, doimiy IP va boshlang‘ich dalillar	1.5
SSH kaliti, hisob/interfeys cheklovi va keraksiz xizmatni yopish	2.0
Firewall, kernel va log siyosati; ishlaydigan tranzit	2.0
Ijobiy/salbiy sinovlar, oldin/keyin audit va tahlil	2.0
Zaxira, tanlab tiklash va reboot tekshiruvi	1.5
Aniq hisobot va og‘zaki himoya	1.0

Faqat konfiguratsiya matni mavjudligi to‘liq ball bermaydi: tegishli ishlash dalili bo‘lishi shart. Salbiy sinovdagi uzilish bilan birga ruxsat etilgan xizmatning ishlashi ham ko‘rsatiladi.

13. Hisobot tarkibi, himoya savollari va manbalar

Hisobot tarkibi

Titul: fan, A16, 1-variant, 5-semestr, F.I.Sh., guruh va sana. Asosiy qism: maqsad; VM resurslari va topologiya; IP jadvali; boshlang‘ich topilmalar; yakuniy siyosat; T1–T12; zaxira/tiklash dalili; qoldiq xavflar va xulosa. Konfiguratsiya parchalari izoh bilan beriladi.

Kamida 6 ta skrinshot: (1) IP va route; (2) boshlang‘ich ADMIN/CLIENT skani; (3) sshd -T va yakuniy listener; (4) nft qoidalari, counter/log; (5) ruxsat etilgan SSH/HTTP va rad etilgan ulanishlar; (6) RESTORE_OK hamda rebootdan keyingi audit. Matnli loglarni ham ilova qiling; parol va yopiq kalitni ilova qilmang.

Himoya savollari

1. Routerga yo‘naltirilgan va router orqali o‘tuvchi paket qaysi chain’da tekshiriladi?
2. Xizmatni o‘chirish va uning portini firewall bilan yopish qanday farq qiladi?
3. sshd -t, sshd -T va ss -lntp qanday turli dalillar beradi?
4. Kalit bilan kirishni parolni o‘chirishdan oldin nega tekshirish kerak?
5. AllowUsers va IP filtri bir-birini qanday to‘ldiradi?
6. ct state established,related qoidasining vazifasi nima?
7. filtered natijasidan “xizmat mavjud emas” xulosasini chiqarish mumkinmi?
8. Log rate limit nima uchun paketga ruxsat beruvchi limit emas?
9. Konfiguratsiya arxivi va VM snapshotining farqi nimada?
10. 10 PASS natija nimani isbotlaydi va nimalarni isbotlamaydi?

Foydalanilgan rasmiy manbalar

[1] Ubuntu Server — OpenSSH server. https://ubuntu.com/server/docs/how-to/security/openssh-server/

[2] Ubuntu — SSH socket activation. https://discourse.ubuntu.com/t/sshd-now-uses-socket-based-activation-ubuntu-22-10-and-later/30189

[3] Netplan — configuration examples. https://netplan.readthedocs.io/en/stable/examples/

[4] Nmap — Port Scanning Basics. https://nmap.org/book/man-port-scanning-basics.html

[5] OpenSSH — sshd_config(5). https://man.openbsd.org/sshd_config

[6] Linux kernel — IP Sysctl. https://docs.kernel.org/networking/ip-sysctl.html

[7] systemd — journald.conf. https://www.freedesktop.org/software/systemd/man/latest/journald.conf.html

[8] Netfilter — nft manual. https://www.netfilter.org/projects/nftables/manpage.html

Buyruqlar Ubuntu Server 24.04 LTS o‘quv muhiti uchun tuzilgan. Versiya va hypervisorga qarab interfeys nomlari farq qiladi. O‘qituvchi tayyor obrazlarda to‘liq funksional sinovni darsdan oldin bajaradi; hujjatdagi kutiladigan natijalar talabaning amaliy o‘lchovlari bilan tasdiqlanadi.